○ E-LEARNING · ESTUDOS

Nicloud · Segurança na AWS

Módulo 1 – Service Control Policies na prática

Sumário

Objetivos de aprendizagem 2
Arquitetura 2
Service Control Policies (SCP) 3
Por que Deny e não Allow 3
Restringir regiões 4
Exemplo: região neste repo 4
Trancar o IAM e a base de segurança 4
Criptografia obrigatória 5
Exemplo: a armadilha do IfExists 5
Tags obrigatórias 6
Exigir IMDSv2 6
Exemplo: IMDSv2 neste repo 6
Bloqueio por país 7
Exemplo: as exceções que não quebram a AWS 7
Limite de tamanho da SCP 7
Testar uma SCP antes de aplicar 8
Resumo 8
Quiz 8
Recursos adicionais 9

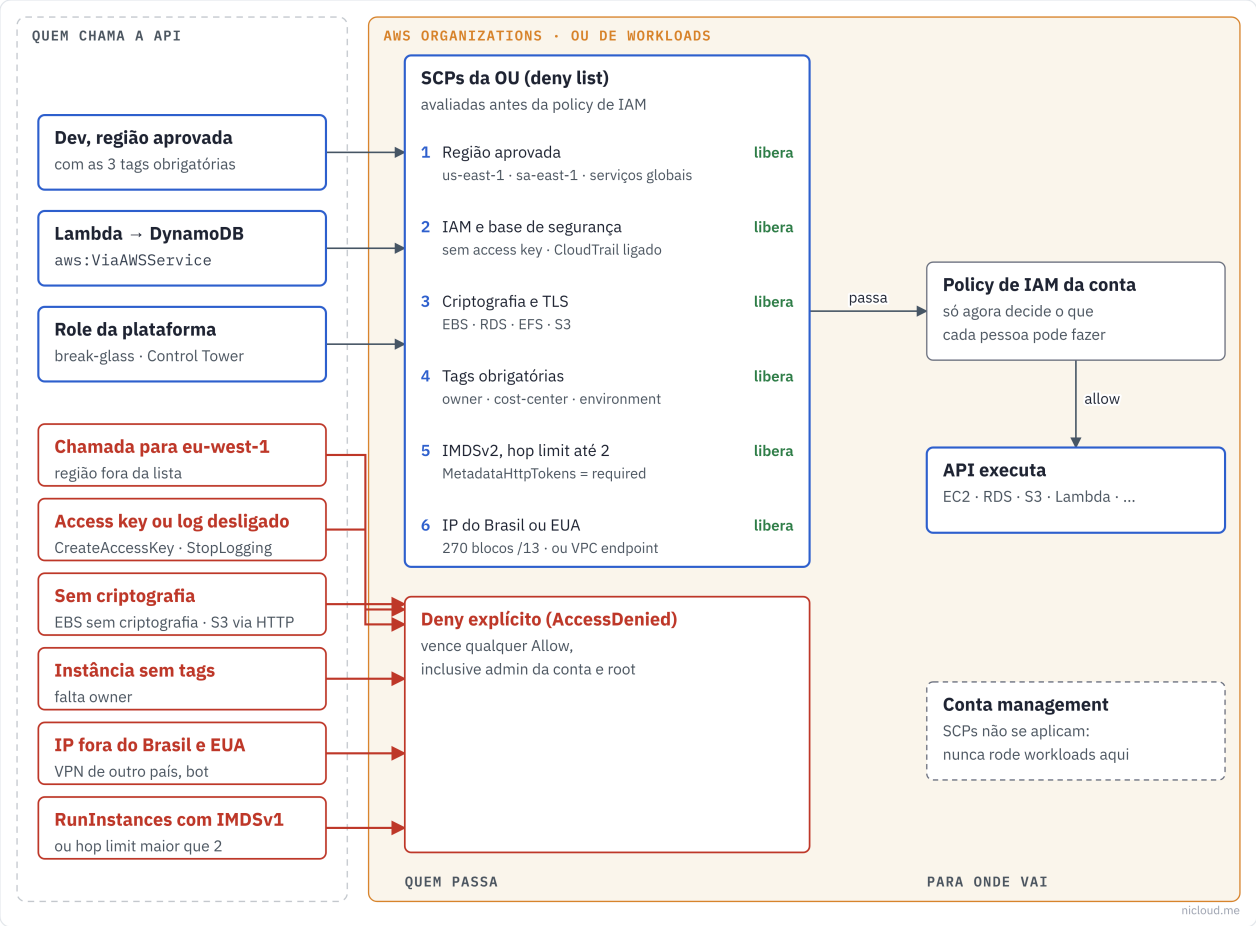
Objetivos de aprendizagem

Neste módulo, você vai aprender a:

- Descrever o que uma **Service Control Policy (SCP)** faz e o que ela não faz.
- Diferenciar uma SCP de uma policy de IAM.
- Explicar por que as SCPs deste repositório usam **Deny** e não Allow.
- Ler uma condição de SCP (`StringNotEquals`, `NumericGreaterThan`, `NotIpAddress`, `BoolIfExists`).
- Restringir as **regiões** sem quebrar os serviços globais.
- Trancar o **IAM** e a **base de segurança** (CloudTrail, Config, GuardDuty) contra quem tem acesso de administrador.
- Exigir **criptografia** no S3, EBS, RDS e EFS e entender a armadilha do `IfExists`.
- Exigir **tags** de dono, centro de custo e ambiente na criação dos recursos.
- Exigir **IMDSv2** em todas as instâncias EC2 da organização.
- Montar um bloqueio por país sem quebrar chamadas entre serviços da AWS.
- Respeitar o limite de tamanho de uma SCP e conferir quando ele muda.
- **Testar** uma SCP antes de aplicar, com o IAM Access Analyzer e testes automatizados.

Arquitetura

Visão geral do que este repositório faz, no padrão de diagrama da Nicloud: à esquerda quem chama, no meio as seis regras, à direita para onde vai. Em azul, o que passa; em vermelho, o que cai no Deny.



Service Control Policies (SCP)

Uma **Service Control Policy** é uma regra do **AWS Organizations** que define o **máximo de permissão** que as contas de uma unidade organizacional (OU) podem ter. Ela não dá permissão a ninguém: só tira.

Pense na SCP como o teto do prédio. A policy de IAM decide o que cada pessoa pode fazer lá dentro, mas ninguém passa do teto, nem o usuário root da conta-membro.

- Uma ação só acontece se **a SCP permite e a policy de IAM permite**.
- A SCP não vale para a **conta de gerenciamento** da organização.
- A SCP não vale para **service-linked roles**.

Quando usar

Use SCP para regras que **nenhuma** conta pode quebrar, nem por engano, nem com acesso de administrador: região permitida, criptografia obrigatória, padrão de segurança de instância, bloqueio de origem.

Por que Deny e não Allow

A estratégia deste repositório é a **deny list**: a SCP padrão `FullAWSAccess` continua anexada e cada arquivo daqui acrescenta um **Deny** específico. O Deny explícito sempre vence qualquer Allow.

A alternativa (allow list, que tira o `FullAWSAccess` e lista só o permitido) dá mais controle, mas cada serviço novo exige mudar a SCP. Para uma biblioteca reutilizável, a deny list é mais segura de aplicar sem parar ninguém.

Restringir regiões

A **restrição de região** nega qualquer ação fora das regiões aprovadas. Ela evita recurso criado onde ninguém monitora, sem orçamento e fora do escopo de compliance.

O cuidado é com os **serviços globais**: IAM, STS, Organizations, Route 53, CloudFront, Support e o faturamento têm o endpoint em `us-east-1`. Se a SCP negar tudo fora de `sa-east-1`, o console para de funcionar e ninguém consegue assumir role.

Exemplo: região neste repo

```
// policies/region-restriction/deny-non-approved-regions.json
{
  "Sid": "DenyOutsideApprovedRegions",
  "Effect": "Deny",
  "NotAction": ["iam:*", "sts:*", "route53:*", "cloudfront:*", "support:*",
"..."],
  "Resource": "*",
  "Condition": {
    "StringNotEquals": { "aws:RequestedRegion": ["us-east-1", "sa-east-1"] },
    "ArnNotLike": { "aws:PrincipalArn":
["arn:aws:iam::*:role/OrganizationAccountAccessRole", "..."] }
  }
}
```

Como funciona

(1) `NotAction` em vez de `Action`

O Deny vale para **todas as ações menos** as da lista. É a lista de serviços globais do exemplo da AWS. Serviço global novo precisa entrar nela.

(2) A role da plataforma fica de fora

`ArnNotLike` em `aws:PrincipalArn` libera as roles de recuperação (`OrganizationAccountAccessRole`, `AWSControlTowerExecution` e `break-glass-admin`). Assim o time de plataforma sempre consegue entrar e consertar.

Trancar o IAM e a base de segurança

A policy `iam-lockdown` junta cinco regras que um invasor tentaria quebrar primeiro:

Statement	O que nega	Por quê
`DenyLongLivedIamUserCredentials`	criar usuário IAM, access key e senha de console	pessoas entram por SSO; workloads usam role
`ProtectPlatformRoles`	mexer nas roles de recuperação e nas roles do SSO	uma role de dev comprometida não toma a conta
`ProtectSecurityBaseline`	desligar CloudTrail, Config, GuardDuty, Security Hub e Access Analyzer	a primeira coisa que o invasor faz é apagar o rastro
`DenyLeavingOrganization`	sair da organização	fora da organização, nenhuma SCP vale
`DenyRootUser`	qualquer ação do root das contas-membro	root só para o que exige root

Repare que `DenyLeavingOrganization` não tem exceção nem para a role de administrador.

Criptografia obrigatória

A policy `require-encryption` nega S3 sem TLS (`aws:SecureTransport = false`), volume EBS, banco RDS e EFS criados sem criptografia. Também impede desligar a criptografia padrão do EBS.

Exemplo: a armadilha do IfExists

A primeira versão da regra de upload no S3 usava `StringNotEqualsIfExists`. O teste automático pegou o erro: **um operador `...IfExists` é verdadeiro quando a chave não existe**. Como a maioria dos uploads não manda o cabeçalho de criptografia (o S3 já criptografa todo objeto novo por padrão desde 2023), a regra negaria quase tudo.

```
// policies/require-encryption/require-encryption.json
"Condition": {
  "Null":            { "s3:x-amz-server-side-encryption": "false" },
  "StringNotEquals": { "s3:x-amz-server-side-encryption": ["AES256", "aws:kms",
"aws:kms:dsse"] }
}
```

`Null = false` quer dizer "a chave **existe**". Agora o Deny só vale quando o upload pede um tipo de criptografia fora da lista.

Lição

Operadores negativos (`StringNotEquals`, `ArnNotLike`, `NotIpAddress`) e os terminados em `IfExists` são **verdadeiros quando a chave falta**. Sempre pergunte: o que acontece quando a chave não vem na requisição?

Tags obrigatórias

A policy `tag-enforcement` exige `owner`, `cost-center` e `environment` (com valor `dev`, `staging` ou `prod`) ao criar instância EC2, volume EBS, banco RDS e função Lambda. A condição é `Null` em `aws:RequestTag/<chave>`: se a tag não veio na requisição, nega.

O `Resource` limita a regra a esses tipos. O `RunInstances` também toca sub-rede, security group e interface de rede. Sem esse filtro, a criação inteira falharia. Uma quarta regra impede apagar essas tags depois.

Exigir IMDSv2

O **Instance Metadata Service (IMDS)** é o endereço `169.254.169.254` de onde a instância lê dados sobre si mesma, inclusive as **credenciais temporárias da role**. A versão 1 responde a um GET simples, e por isso um ataque de **SSRF** (a aplicação é enganada a fazer uma requisição) consegue roubar as credenciais. A **versão 2** exige um token obtido antes com um PUT.

Exemplo: IMDSv2 neste repo

```
// policies/imdsv2-enforcement/enforce-imdsv2.json
{
  "Sid": "RequireIMDSv2OnRunInstances",
  "Effect": "Deny",
  "Action": "ec2:RunInstances",
  "Resource": "arn:aws:ec2:*:*:instance/*",
  "Condition": {
    "StringNotEquals": { "ec2:MetadataHttpTokens": "required" }
  }
}
```

Como funciona

(1) Exigir o token

O primeiro statement nega o `RunInstances` quando `MetadataHttpTokens` não é `required`. Instância nova só nasce com IMDSv2.

(2) Limitar os saltos

O segundo statement nega quando `MetadataHttpPutResponseHopLimit` passa de **2**. O hop limit é quantos "pulos" de rede a resposta do token aguenta. Com 2, um container na instância ainda alcança o IMDS; com mais que isso, fica mais fácil o token escapar para fora.

O que fica de fora

Esta SCP vale para instâncias **novas**. Instâncias antigas com IMDSv1 continuam como estão: é preciso migrar com `modify-instance-metadata-options` e, para impedir a volta, negar também essa ação quando o valor não for `required`.

Bloqueio por país

A segunda policy nega chamadas de API que venham de IPs fora do Brasil e dos Estados Unidos. A condição principal é **`NotIpAddress`** com `aws:SourceIp`: se o IP de origem **não** está na lista, a chamada é negada.

O problema é que nem toda chamada tem o IP de uma pessoa. Quando a Lambda chama o DynamoDB, ou quando o ECS baixa uma imagem do ECR, quem chama é a própria AWS.

Exemplo: as exceções que não quebram a AWS

```
// policies/geo-restriction/deny-access-from-non-allowed-countries.json
"Condition": {
  "NotIpAddress":   { "aws:SourceIp": ["177.0.0.0/13", "..."] },
  "BoolIfExists":   { "aws:ViaAWSService": "false" },
  "StringNotLike":  { "aws:SourceVpce": "vpce-*" }
}
```

As três condições precisam ser verdadeiras ao mesmo tempo para o Deny valer:

Condição	O que garante
`NotIpAddress`	o IP está fora da lista permitida
`BoolIfExists` `aws:ViaAWSService: false`	não é um serviço da AWS chamando em nome de alguém
`StringNotLike` `aws:SourceVpce: vpce-*`	não veio por VPC Endpoint (que não tem IP público)

De onde vêm os IPs

O script `generate-country-cidrs.sh` baixa a lista de delegações dos registros regionais (**LACNIC** para o Brasil, **ARIN** para os Estados Unidos), filtra pelo país e agrega os blocos em **/13**.

Limite de tamanho da SCP

Hoje uma SCP aceita até **10.240 caracteres** (o limite de 5.120 vale para as **Resource Control Policies**). Pelo console, os espaços e quebras de linha entre os elementos do JSON são removidos e não contam; pela CLI ou SDK, o texto é salvo como está e tudo conta.

O arquivo do bloqueio por país tem 8.375 caracteres formatado e **4.691 minificado**. Os dois cabem hoje. A escolha por blocos **/13** foi feita quando o limite era 5.120: com o limite atual, dá para usar blocos menores e mais precisos, que incluem menos IPs de países vizinhos.

Lição

Limite de serviço muda. Antes de decidir um trade-off por causa de um limite, confira o número na documentação do dia e anote a data no README.

Testar uma SCP antes de aplicar

Uma SCP errada derruba a produção inteira de uma vez. Este repositório usa duas camadas de teste:

1. **IAM Access Analyzer** (`validate-policy` com `--policy-type SERVICE_CONTROL_POLICY`): confere a sintaxe e aponta más práticas. Ele pegou um `StringLike` em `aws:PrincipalArn`, que deveria ser `ArnLike`.
2. **Testes automatizados** (`pytest`): um avaliador pequeno de SCP (`tests/scp_eval.py`) simula 20 cenários, como "instância sem a tag `environment` é negada" e "o IAM continua funcionando fora das regiões aprovadas". A esteira roda tudo a cada push.

Mesmo com os testes verdes, aplique uma policy por vez, primeiro numa OU de sandbox. Depois acompanhe no CloudTrail os `AccessDenied` com "explicit deny in a service control policy".

Resumo

Uma **SCP** é o teto de permissão das contas de uma organização: ela só tira, nunca dá, e vale até para o root da conta-membro. Este repositório usa a estratégia de **deny list**, mantendo o `FullAWSAccess` e somando negações específicas.

A policy de **IMDSv2** impede que nasça instância com a versão 1 do serviço de metadados, que é a porta de entrada mais comum para roubo de credencial via **SSRF**, e limita o **hop limit** a 2.

A policy de **bloqueio por país** nega chamadas de fora do Brasil e dos Estados Unidos, mas só depois de excluir chamadas de **serviços da AWS** e de **VPC Endpoints**. Sem essas duas exceções, ela derrubaria a própria infraestrutura.

A **restrição de região** nega tudo fora das regiões aprovadas, menos os **serviços globais** listados no `NotAction`. O **iam-lockdown** proíbe usuário IAM e access key, protege as roles de recuperação, impede desligar CloudTrail, Config e GuardDuty, impede sair da organização e bloqueia o root. A **criptografia obrigatória** exige TLS no S3 e disco e banco criptografados. As **tags obrigatórias** exigem dono, centro de custo e ambiente na criação.

Cuidado com operadores negativos e `IfExists`: eles são verdadeiros quando a chave falta.

E toda SCP precisa caber em **10.240 caracteres**: minifique o JSON quando enviar pela CLI, porque ali os espaços contam.

Quiz

Um administrador da conta-membro tem `AdministratorAccess`, mas não consegue criar uma instância. A policy de IAM está certa. O que verificar?

- Uma SCP na OU da conta. A SCP limita até o administrador e o root da conta-membro.

Você precisa garantir que nenhuma instância nova da organização use IMDSv1. Qual condição usar no Deny de `ec2:RunInstances`?

- `StringNotEquals` em `ec2:MetadataHttpTokens` com valor `required`.

Depois de aplicar o bloqueio por país, a Lambda parou de gravar no DynamoDB. Qual exceção provavelmente falta?

- `aws:ViaAWSService`. A chamada vem do serviço, não do IP de uma pessoa.

Uma SCP com 11.000 caracteres formatados dá erro ao salvar pela CLI, mas o conteúdo minificado tem 9.000. O que fazer?

- Minificar o JSON antes de enviar. Pela CLI os espaços contam; o limite da SCP é 10.240 caracteres.

A SCP de IMDSv2 resolve as instâncias que já existem com IMDSv1?

- Não. Ela só vale para `RunInstances`. As instâncias antigas precisam ser migradas com `modify-instance-metadata-options`.

Um desenvolvedor não consegue criar uma role em `eu-west-1`, mas a SCP de região só permite `us-east-1` e `sa-east-1`. Isso é esperado?

- Não. IAM é serviço global e está no `NotAction`, então criar role funciona de qualquer região. Se negou, confira se a lista de serviços globais está completa.

Uma regra com `StringNotEqualsIfExists` em `s3:x-amz-server-side-encryption` passou a negar quase todos os uploads. Por quê?

- `IfExists` é verdadeiro quando a chave falta. A maioria dos uploads não manda esse cabeçalho. Use `Null = false` junto com `StringNotEquals`.

Por que a tag-enforcement limita o `Resource` a `instance/*` e `volume/*` no `RunInstances`?

- Porque o `RunInstances` também toca sub-rede, security group e interface de rede, que não recebem as tags. Sem o filtro, toda criação seria negada.

Qual statement do iam-lockdown não tem exceção nem para a role de administrador?

- `DenyLeavingOrganization`. Uma conta fora da organização perde todas as SCPs.

A SCP vale para a conta de gerenciamento da organização?

- Não. Por isso nada deve rodar na conta de gerenciamento além da própria administração da organização.

Recursos adicionais

- Service control policies (AWS Organizations)
- Exemplos de SCP
- Limites do AWS Organizations
- Configurar o serviço de metadados da instância (IMDS)
- Validação de policies com o IAM Access Analyzer
- Operadores de condição do IAM
- Chaves de condição globais do IAM